

Untuk **level Hard**, fokusnya bukan sekadar menemukan satu kerentanan lalu root, tetapi menggabungkan banyak tahap: enumerasi, analisis source code, penyalahgunaan konfigurasi, pivot antar-user, dan privilege escalation yang lebih kompleks.

Karena teknik hard sering mendekati kemampuan yang dapat diterapkan pada sistem nyata, saya akan membahasnya sebagai **desain lab/CTF dan tujuan pembelajaran**, bukan langkah eksploitasi operasional.

## Boot2Root Hard – "CorpDev"

### Tingkat Kesulitan



### Materi yang Dipelajari

- Advanced Enumeration
- Virtual Host Discovery
- Git Exposure
- Source Code Review
- Credential Harvesting
- Password Reuse
- Horizontal Privilege Escalation
- Scheduled Task Abuse
- Linux Capabilities
- Root Escalation

---

### Storyline

Sebuah tim developer memiliki portal internal.

Karena kesalahan deployment:

- Repository Git terekspos.
- Ada kredensial lama yang masih digunakan.
- Terdapat beberapa user sistem.
- Salah satu service berjalan dengan capabilities yang berlebihan.

Peserta harus bergerak dari web → developer → ops → root.

---

### Jalur Penyelesaian

Nmap



Virtual Host Discovery

↓

Git Exposure

↓

Source Code Analysis

↓

Credential Discovery

↓

SSH Login (developer)

↓

Horizontal Escalation (ops)

↓

Capability Misconfiguration

↓

Root

---

## User di Sistem

### User 1

developer

Hak terbatas.

---

### User 2

ops

Memiliki akses ke script maintenance.

---

### Root

Target akhir.

---

## Service yang Berjalan

### Port Service

22    SSH

## Port Service

80 Apache

8080 Internal App

---

### Tahap 1 – Enumerasi

Peserta menemukan:

22/tcp

80/tcp

8080/tcp

Namun website utama tidak mengandung apa pun yang menarik.

---

### Tahap 2 – Virtual Host

Hint:

dev.corp.local

Subdomain ini mengarah ke aplikasi developer.

Tujuan pembelajaran:

- vhost enumeration
  - host header awareness
- 

### Tahap 3 – Git Exposure

Developer lupa menghapus:

.git/

Peserta dapat merekonstruksi repository.

Tujuan:

- memahami risiko source code exposure
  - menganalisis commit history
- 

### Tahap 4 – Source Code Review

Commit lama mengandung:

database credentials

yang seharusnya sudah dihapus.

Peserta belajar:

- secret leakage
  - commit history analysis
  - credential harvesting
- 

## **Tahap 5 – Credential Reuse**

Password database ternyata juga digunakan oleh:

developer

untuk SSH.

Ini mengajarkan:

- reuse password
  - credential hygiene
- 

## **User Flag**

/ home/developer/user.txt

---

## **Tahap 6 – Horizontal Escalation**

Di home developer ditemukan:

backup script

yang mengandung kredensial user:

ops

Peserta berpindah:

developer

↓

ops

Ini adalah:

## **Horizontal Privilege Escalation**

karena kedua akun bukan root.

---

## **Tahap 7 – Capabilities Abuse**

Saat enumerasi, peserta menemukan binary dengan capability berlebihan.

Contoh konsep:

cap\_setuid

atau capability lain yang tidak seharusnya dimiliki program tersebut.

Tujuan pembelajaran:

- mengenal Linux capabilities
- memahami perbedaan dengan SUID

---

## Root Flag

/root/root.txt

Isi:

FLAG{corpdev\_root}

---

## Hint yang Disediakan

### Hint 1

Not everything is visible on the main website.

---

### Hint 2

Developers often forget old commits.

---

### Hint 3

Check system capabilities.

---

## Apa yang Dipelajari

Peserta akan memahami:

### Enumerasi Lanjutan

Tidak semua informasi ada di halaman utama.

---

## Source Code Review

Membaca kode sering lebih penting daripada eksploitasi teknis.

---

## Secret Leakage

Banyak kompromi terjadi karena kredensial bocor.

---

## Horizontal Escalation

Tidak semua eskalasi langsung menuju root.

---

## Capabilities

Linux modern tidak hanya bergantung pada SUID.

---

## Versi Hard+ (Mendekati OSCP)

Setelah CorpDev, Anda bisa membuat mesin yang mencakup:

Web App

↓

Credential Leak

↓

User Shell

↓

Docker Misconfiguration

↓

Container Escape (lab)

↓

Root

atau

Git Exposure

↓

SSH

↓

Pivot ke User Kedua

↓

sudo Misconfiguration

↓

Root

atau

CVE Discovery



Limited Access



Lateral Movement



Capability Abuse



Root

Desain yang baik untuk level Hard biasanya memiliki **2–4 langkah independen yang harus ditemukan dan dirangkai**, bukan satu kerentanan tunggal yang langsung memberikan akses root. Itu melatih pola pikir yang lebih mirip penilaian keamanan nyata maupun CTF Boot2Root tingkat lanjut.